

Digital Twin Security & Access

Digital Twin is designed for system-to-system integrations rather than direct end-user access. Digital channels, payment processors, core banking systems, and other trusted applications communicate with Digital Twin through secure APIs and Kafka messaging. End users never authenticate directly with Digital Twin; instead, trusted systems authenticate and act on behalf of their customers.

Authentication & Authorization

Digital Twin secures API access using OAuth 2.0 and OpenID Connect (OIDC), typically implemented through an identity provider such as Keycloak.

Each integrated system authenticates using client credentials and receives an access token containing the roles or scopes assigned by the financial institution. Digital Twin validates every request by verifying the token's signature, issuer, expiration, and granted permissions before processing the request.

This allows financial institutions to control access at a granular level. For example:

- A payment processor may be authorized to submit payment transactions.
- A digital channel may be authorized to retrieve balances and transaction history.
- Administrative services may be granted configuration privileges.

Every API call is authorized according to the permissions contained in the caller's access token.

Secure Communications

Digital Twin protects communication between systems using industry-standard transport security.

- REST APIs support HTTPS with OAuth2 authentication.
- Mutual TLS (mTLS) may be used to provide mutual authentication between trusted systems.
- Kafka communications can leverage Kafka's native TLS encryption and authentication mechanisms.

These controls protect data in transit while ensuring that only authorized systems communicate with Digital Twin.

Idempotency & Auditability

Each financial operation includes a unique correlation ID (idempotency key) that prevents duplicate processing caused by retries or network failures.

Digital Twin maintains a complete audit trail of financial operations and system activity, allowing institutions to trace requests, responses, and resulting transactions.

Event Processing

Digital Twin is built using Domain-Driven Design (DDD), where the account serves as the primary consistency boundary.

Events associated with a single account are processed sequentially to preserve transaction ordering. This ensures, for example, that an account creation event is processed before any subsequent transactions for that account.

Every event receives a unique identifier that enables reliable tracking and ordering throughout the platform.

Data Protection

Digital Twin is designed to minimize sensitive data storage.

Personally Identifiable Information (PII) is not stored within Digital Twin. As a result, database encryption is not enabled by default, although institutions may enable database encryption based on their own security and regulatory requirements.

Standards

Digital Twin follows widely adopted industry standards to maximize interoperability and consistency across integrated systems.

STANDARD**PURPOSE****OAuth 2.0 / OpenID Connect (OIDC)**

Authentication and authorization

mTLS

Mutual authentication and encrypted communications

ISO 8601

Date and time formatting

RFC 7807

Standardized API error responses

JSR 354

Monetary values and currency handling

ISO 25010

Software quality model and architecture guidance